

互联网医疗健康移动应用软件（APP）个人信息保护技术要求

Technical Requirements for Personal Information Protection of Internet Health Care App

(点击此处添加与国际标准一致性程度的标识)

(报批稿)

(本草案完成时间：2022-12-28)

在提交反馈意见时，请将您知道的相关专利连同支持性文件一并附上。

2023 - XX - XX 发布

2023 - XX - XX 实施

中华人民共和国工业和信息化部 发布

目 次

前言	II
1 范围	1
2 规范性引用文件	1
3 术语和定义	1
3.1	1
3.2	1
3.3	1
3.4	1
3.5	2
4 概述	2
4.1 基本原则	2
4.2 互联网医疗健康 App 个人信息分类	2
4.2.1 个人属性信息	2
4.2.2 个人健康状况信息	2
4.2.3 个人医疗应用信息	3
4.2.4 个人遗传信息	3
5 互联网医疗健康 App 个人信息保护要求	3
5.1 互联网医疗健康 App 网络安全管理	3
5.1.1 互联网医疗健康 App 安全保护管理	3
5.1.2 互联网医疗健康 App 应急处置管理	3
5.1.3 互联网医疗健康 App 网络运营管理	3
5.2 互联网医疗健康 App 个人信息处理活动保护要求	3
5.2.1 互联网医疗健康 App 个人信息收集	3
5.2.2 互联网医疗健康 App 个人信息存储	3
5.2.3 互联网医疗健康 App 个人信息使用	4
5.2.4 互联网医疗健康 App 个人信息删除	4
5.2.5 互联网医疗健康 App 个人信息向第三方共享、转让、委托处理、公开披露	4
附录 A（资料性） 互联网医疗健康 App 个人信息安全风险	5
参考文献	6

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院，工业互联网创新中心（上海）有限公司，北京智游网安科技有限公司，北京京东尚科信息技术有限公司，北京百度网讯科技有限公司，北京纵横无双科技有限公司，北京三星通信技术研究有限公司，郑州信大捷安信息技术股份有限公司

本文件主要起草人：闵栋、何友斌、金越、彭浩、罗达、章向明、武国平、董嘉强、金亦然、刘为华、李真真、魏嵩磊、李月、张斯琴、翁祖昊、曹远晶、韩云、曹倩、康亮

互联网医疗健康移动应用软件（APP）个人信息保护技术要求

1 范围

本文件规定了互联网医疗健康App网络安全管理、互联网医疗健康App个人信息处理活动等方面的技术保护要求。

本文件适用于指导第三方评估机构对互联网医疗健康App个人信息保护能力进行评估，协助主管监管部门对互联网医疗健康App个人信息保护工作进行监督管理，也可以作为技术参考指导互联网医疗健康App提供者开展互联网医疗健康App个人信息保护能力自评。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069 信息安全技术术语

GB/T 35273 信息安全技术 个人信息安全规范

3 术语和定义

GB/T 25069、GB/T 35273界定的以及下列术语和定义适用于本文件。

3.1

个人信息 personal information

以电子或者其他方式记录的能够单独或者与其他信息结合识别特定自然人身份或者反映特定自然人活动情况的各种信息。

[GB/T 35273，术语和定义3.1]

3.2

个人信息主体 personal information subject

个人信息所标识或者关联的自然人。

[GB/T 35273，术语和定义3.3]

3.3

互联网医疗健康 App Internet health care application

运行在移动智能终端上的具有医疗健康属性的应用程序及应用程序内的第三方服务。

注：包括移动智能终端预置、下载安装的应用程序和小程序，简称App；以及依托于应用程序的第三方服务，例如微信公众号。

3.4

互联网医疗健康App个人信息 Personal information of Internet health and medical application

能够通过互联网医疗健康App进行处理，涉及个人过去、现在或将来的身体或心理健康状况、接受的医疗保健服务和与医疗保健服务相关的支付信息等，能够反映单独或者与其他信息结合识别特定自然人或者反映特定自然人生理或心理健康相关信息。

3.5

互联网医疗健康App提供者 Internet health care application provider

提供互联网医疗健康App并有能力决定互联网医疗健康App个人信息处理目的、方式等的组织或个人。

4 概述

4.1 基本原则

互联网医疗健康App提供者开展互联网医疗健康App个人信息保护应遵循合法、正当、必要的原则，具体包括：

- a) 权责一致原则——采取技术和其他必要的措施保障互联网医疗健康 App 个人信息的安全，对其个人信息处理活动对个人信息主体合法权益造成的损害承担责任；
- b) 目的明确原则——具有明确、清晰、具体的互联网医疗健康 App 个人信息处理目的；
- c) 授权同意原则——向互联网医疗健康 App 个人信息主体明确信息处理目的、方式、范围等规则，征求其授权同意；
- d) 最小必要原则——只处理满足互联网医疗健康 App 个人信息主体授权同意的目的所需的最少个人信息类型和数量。目的达成后，应及时删除互联网医疗健康 App 个人信息；
- e) 一数之源、最少够用”原则——“一数之源、最少够用”原则。互联网医疗健康 App 提供者应当保证个人在服务端中身份标识的唯一性，基本信息项的一致性，便于信息共享和利用，避免重复采集、多头采集，即“一数之源”。不得超范围采集信息，只采集满足服务和管理工作所需要的最少且够用的相关信息；
- f) 公开透明——以明确、易懂和合理的方式公开处理互联网医疗健康 App 个人信息的范围、目的、规则等，并接受外部监督；
- g) 确保安全——具备与所面临的安全风险相匹配的安全能力，并采取足够的管理措施和技术手段，保护互联网医疗健康 App 个人信息的保密性、完整性、可用性；
- h) 主体参与——向互联网医疗健康 App 个人信息主体提供能够查询、更正、删除其信息，以及撤回授权同意、注销账户、投诉等方法。

4.2 互联网医疗健康 App 个人信息分类

4.2.1 个人属性信息

互联网健康App个人信息包括个人属性信息、健康状况信息、医疗应用数据和个人遗传信息。

个人属性信息主要包括：

- a) 人口统计信息，包括姓名、年龄、性别、民族、国籍、职业、住址、工作单位、家庭成员信息等；
- b) 个人身份信息，包括姓名、身份证、工作证、居住证、社保卡、可识别个人的影像图像等；
- c) 个人通讯信息，包括个人电话号码、邮箱、账号及关联信息等；
- d) 个人生物识别信息，包括基因、指纹、声纹、掌纹、耳廓、虹膜、面部特征等；
- e) 个人信用记录信息，包括个人信用档案、个人信用评分、个人信用报告等。

4.2.2 个人健康状况信息

互联网医疗健康App个人健康状况信息包括：

既往病史（包含传染病史）、社会史、家族史、过敏史、症状、健康体检信息、可穿戴设备采集的健康相关信息、生活方式等。

4.2.3 个人医疗应用信息

互联网医疗健康App个人医疗应用信息包括：

个人在接受医疗健康过程中使用医疗健康App所收集和产生的个人医嘱单、检验报告、诊断结果、用药信息、病程记录、诊治记录、用药记录、手术记录、护理记录、住院记录、医疗效果等信息。

4.2.4 个人遗传信息

互联网医疗健康App个人遗传信息包括：

利用个人遗传资源材料(含有人体基因组、基因等遗传物质的器官、组织、细胞等遗传材料)产生的信息。

5 互联网医疗健康 App 个人信息保护要求

5.1 互联网医疗健康 App 网络安全管理

5.1.1 互联网医疗健康 App 安全保护管理

互联网医疗健康App提供者应参照GB/T 22239中的要求对互联网医疗健康App进行等级保护定级、备案、测评、安全建设整改等工作。

5.1.2 互联网医疗健康 App 应急处置管理

互联网医疗健康App提供者应建立应急处置机制，通过建立完善应急预案、组织应急演练等方式，有效处理网络中断、网络攻击、信息泄露等安全事件，提高应对网络安全事件能力。

5.1.3 互联网医疗健康 App 网络运营管理

- a) 互联网医疗健康 App 提供者应每年开展文档核验、漏洞扫描、渗透测试等多种形式的自查，及时发现可能存在的问题和隐患；
- b) 互联网医疗健康 App 提供者应依据上级主管监管机构要求，完成信息资产梳理，摸清互联网医疗健康 App 网络定级、备案等情况，形成资产清单，组织安全自查；
- c) 互联网医疗健康 App 提供者应依据上级主管监管机构要求，对发现的问题和隐患进行整改，形成整改报告向有关主管监管机构报备。

5.2 互联网医疗健康 App 个人信息处理活动保护要求

5.2.1 互联网医疗健康 App 个人信息收集

互联网医疗健康App 在开展专家问诊、药师咨询、线上买药等业务功能时应满足以下要求：

- a) 互联网医疗健康 App 个人信息收集应参照 GB/T 35273—2020 的第 5 章；
- b) 互联网医疗健康 App 提供者应明确业务部门、管理部门在个人信息收集的主体责任；
- c) 互联网医疗健康 App 提供者应采取数据脱敏、数据加密等安全防护措施，以防止数据安全事件发生。

5.2.2 互联网医疗健康 App 个人信息存储

- a) 互联网医疗健康 App 个人信息存储应参照 GB/T 35273—2020 的第 6 章；
- b) 在传输和存储互联网医疗健康 App 个人信息时，互联网医疗健康 App 提供者应采用传输通道加密、字段加密、数据备份等安全措施；
- c) 互联网医疗健康 App 提供者应针对不同类别的互联网医疗健康 App 个人信息，明确不同安全级别的加密数据要求；
- d) 互联网医疗健康 App 提供者应选择合适的数据存储架构和介质；
- e) 当涉及互联网医疗健康 App 个人信息云存储时，互联网医疗健康 App 提供者应在存储前进行风险评估；
- f) 互联网医疗健康 App 个人信息存储周期应小于数据使用规则确定的保存期限。

5.2.3 互联网医疗健康 App 个人信息使用

- a) 互联网医疗健康 App 个人信息使用应参照 GB/T 35273—2020 的第 7 章；

- b) 应严格规定不同角色的互联网医疗健康 App 个人信息使用权限；
- c) 应明确互联网医疗健康 App 个人信息使用过程的申请以及批准流程管理。

5.2.4 互联网医疗健康 App 个人信息删除

- a) 互联网医疗健康 App 个人信息删除应参照 GB/T 35273—2020 的第 8 章；
- b) 应采用确保互联网医疗健康 App 个人信息无法还原的删除方式；
- c) 应建立互联网医疗健康 App 个人信息删除方案和存储介质销毁方案，包括删除原则、操作流程、以及有效性验证标准；
- d) 应依照互联网医疗健康 App 个人信息分类分级建立互联网医疗健康 App 个人信息删除、存储介质销毁策略和管理制度，明确互联网医疗健康 App 个人信息删除和存储介质销毁的场景、删除对象、删除方式和删除结果。

5.2.5 互联网医疗健康 App 个人信息向第三方共享、转让、委托处理、公开披露

- a) 互联网医疗健康 App 个人信息向第三方共享、转让、委托处理、公开披露应参照 GB/T 35273—2020 的第 9 章；
- b) 在委托处理、共享、转让、公开披露互联网医疗健康 App 个人信息前，应评估可能带来的安全风险，并采取数据脱敏、数据加密、安全通道等安全防护措施；
- c) 应建立互联网医疗健康 App 个人信息内部、外部共享原则、范围、安全制度、审批流程；
- d) 应告知信息主体并获得主体授权后，才可进行信息公开披露；
- e) 应制定公开披露的策略和流程，并将披露互联网医疗健康 App 个人信息控制在最小范围。

附 录 A

(资料性)

互联网医疗健康 App 个人信息安全风险

——互联网医疗健康 App 个人信息违规收集风险

随着互联网医疗健康App的全面渗透，广大用户面临着享受便捷化服务与保护个人信息权利之间的两难抉择。App强制授权、过度索权、超范围收集个人信息现象大量存在，违法违规使用个人信息的关注度始终居高不下。

隐私政策是App提供者告知用户个人信息收集规则的主要途径，是保障用户知情权的基础。运营者应在用户首次注册、登录App时以弹窗、超链接等明显方式提醒用户阅读隐私政策，以直观的方式告知用户收集使用个人信息的目的、方式、范围，使用户充分了解其个人信息如何被收集、存储、使用、传输、共享、销毁，在知情了解的基础上保护其个人信息安全。

——互联网医疗健康 App 个人信息恶意滥用风险

权限控制是移动终端操作系统对于App提供者收集使用用户个人信息的限制，运营者可通过申请权限的方式获取用户个人信息。App过度索权现象已成常态，用户缺少自主选择权，处于要么放弃使用、要么授权的被动地位。过度索取危险权限为违规收集用户个人信息提供了渠道，一旦这些个人信息被不法分子获取滥用，将严重危害用户权益。

——互联网医疗健康 App 个人信息非法获取风险

运营者本地存储用户个人信息的行为通常在用户不知情的情况下发生，存储的个人信息往往是使用App过程中常用的重要信息。发生个人信息泄露事件时，若未对存储的个人信息采取加密等保护措施，用户个人信息将直接被识别利用，降低了不法分子的犯罪难度，极大地增加了用户个人信息被非法获取利用的风险。

——互联网医疗健康 App 个人信息恶意散播风险

私自共享是指App提供者未经用户同意与第三方共享用户个人信息的行为。运营者应在用户跳转至第三方应用前明示用户其个人信息是否被共享及共享后个人信息的传播路径，同时还应根据共享的个人信息私密程度、安全系数的不同，为用户提供是否同意信息共享及信息共享路径的选择权。在App使用过程中，跳转至第三方应用，在用户毫不知情的情况下使其个人信息被第三方获取，将导致用户无法掌握并控制个人信息的传播路径、使用范围及风险系数，极大增加了用户个人信息被恶意散播的风险。

——互联网医疗健康 App 个人信息过度留存风险

App提供者为了提升其市场竞争力而限制用户注销账户的行为，侵犯了用户的选择权、隐私权和平等交易权等权益。无法注销账户或者为完成注销流程需要用户额外提交个人信息的行为，均存在个人信息过度留存风险。

参 考 文 献

- [1] 《网络安全法》
 - [2] 《数据安全法》
 - [3] 《个人信息保护法》
 - [4] GB/T 22239 信息安全技术 网络安全等级保护基本要求
 - [5] GB/T 34978 信息安全技术 移动智能终端个人信息保护技术要求
 - [6] GB/T 39725 信息安全技术 健康医疗数据安全指南
 - [7] GB/T 41391 信息安全技术 移动互联网应用程序（App）收集个人信息基本要求
 - [8] 《移动应用数据安全与个人信息保护白皮书（2019）》
 - [9] 《App违法违规收集使用个人信息自评估指南》
 - [10] 《人口健康信息管理办法(试行)》
 - [11] 《人类遗传资源管理条例》
 - [12] 《国家健康医疗大数据标准、安全和服务管理办法(试行)》
 - [13] 《信息安全技术 数据出境安全评估指南(征求意见稿)》
-